第七章 网络安全



- 网络安全概述
- 防火墙技术
- 加密技术
- 报文鉴别技术
- 身份认证与数字签名

- 随着计算机网络的迅速普及，人们对网络的依赖性更大。国防、金融、教育、科研等诸多应用领域对计算机网络安全性能也提出了更高的要求。
- 本章重点介绍目前用于保障网络安全的多种技术，如防火墙技术、加密技术、数字签名及认证技术等。

§7.1 网络安全概述

- 计算机网络安全包括物理安全和逻辑安全。
  - 物理安全是指对系统设备及相关设施的物理保护，防止破坏和丢失。
  - 逻辑安全则是指信息可用性、完整性和保密性三大要素的保护。

- 计算机网络安全的核心是逻辑安全
- 计算机网络安全关注的焦点是如何防止对数据的窃取、伪造和破坏。

网络系统面临的安全威胁（1）

1. 窃听：攻击者通过监视网络数据获得敏感信息。
2. 重传：攻击者获得部分或全部信息，并将此信息发送给接收方。
3. 伪造：攻击者将伪造的信息发送给接收方。
4. 篡改：攻击者对合法用户之间的通讯信息进行修改、删除、插入，再发送给接收方。
5. 拒绝服务攻击：攻击者通过某种方法使系统响应减慢甚至瘫痪，阻止合法用户获得服务。
6. 行为否认：通讯实体否认已经发生的行为。

网络系统面临的安全威胁（2）

7. 非授权访问：没有预先经过同意，就使用网络或计算机资源的行为被看作非授权访问。主要有以下几种形式：假冒、身份攻击、非法用户进入网络系统进行违法操作、合法用户以未授权方式进行操作等。
8. 传播病毒：通过网络传播计算机病毒，其破坏性非常高，而且用户很难防范。
9. 人为无意识地损坏。
10. 自然灾害。
11. 其他因素造成的损害。

被动攻击和主动攻击

黑客对计算机网络的攻击方式可以分为被动攻击和主动攻击两类

- 被动攻击
  - 不影响通信双方正常信息交流的攻击方式。
  - 被动攻击主要是收集信息，攻击者的目的是获取正在传输的信息，不影响通信双方正常通信。数据的合法用户对这种活动不会觉察到。
  - 被动攻击包括嗅探、信息收集、窃听等方法。
  - 防止被动攻击最常用的技术是加密。即使这些内容被截获，也无法从加密报文中获得信息。

被动攻击和主动攻击



- 主动攻击
  - 攻击者带破坏目的访问所需信息的故意行为。攻击者是在主动地做一些不利于通信双方的信息交流工作。
  - 主动攻击包括拒绝服务攻击（DoS）、分布式拒绝服务（DDoS）、信息篡改、资源的非法使用、欺骗、伪装、重放等攻击方法。

被动攻击和主动攻击

① 伪装是一个实体假装成另外一个实体。伪装攻击往往连同另一类主动攻击一起进行。例如，身份鉴别的序列被捕获，并在有效的身份鉴别发生时做出回答，有可能使非授权实体得到额外的权力。

② 重放攻击包含数据单元的被动捕获，随之再重传这些数据，从而产生一个非授权的效果。

③ 修改报文攻击意味着合法报文的某些部分已被修改，或者报文的延迟和重新排序，从而产生非授权的效果。

④ 拒绝服务DoS攻击是指利用合理的服务请求来占用过多的服务资源，从而使合法的用户得不到服务响应。这种攻击行为使网站服务器充斥大量要求回复的信息，消耗网络带宽或系统资源，导致网络或系统不胜负荷以至于瘫痪而停正提供正常的网络服务。

⑤ 分布式拒绝服务（DDoS，洪水攻击）是在传统的Dos攻击基础上产生的一类攻击方式，它使许多分布的主机同时攻击一个目标，从而使目标瘫痪。

网络系统面临的安全威胁

1. 一个比较完善的DDos攻击体系分为四大部分：黑客，控制傀儡机，攻击傀儡机，受害者。
2. 最重要的是第二，三部分，分别用于控制和实际发起攻击。
3. 对于第四部分的受害者来说，DDos的实际攻击包是从第三部分的攻击傀儡机上发起的，第二部分只发布控制命令而不参加实际的攻击。
4. 主动攻击难以预防，但却容易检测，所以重点是在于检测并从破坏中回复。

计算机网络信息系统安全的目标



1. 身份真实性：能鉴别通讯实体的真实身份。
2. 信息机密性：能保证机密信息不会泄露给非授权的人或实体。
3. 信息完整性：能保证数据的一致性，防止数据被非授权用户或实体建立、修改和破坏。
4. 服务可用性：能保证合法用户对信息和资源的使用不被拒绝。

计算机网络信息系统安全的目标

5. 不可否认性：建立有效的责任机制，防止实体抵赖或否认其行为。
6. 系统可控性：能够控制使用资源的人或实体的使用方式。
7. 系统易用性：系统应当操作简单、维护方便。
8. 可审查性：为网络提供包括技术在内的各种审查手段以保障信息的安全。

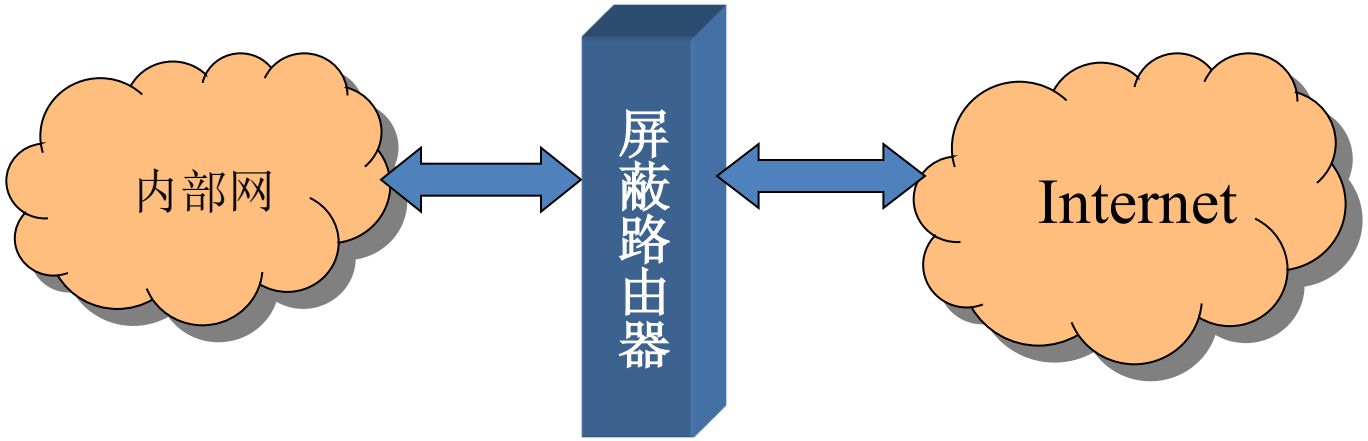
§7.2防火墙技术



- 防火墙是一个分析器和过滤器，其目标是有效地监控内部网和Internet之间的任何活动，保证内部网络的安全。
- 防火墙的安全技术包括包过滤技术、代理技术等。

包过滤技术

- 包过滤技术(Packet Filter) 通过设备对进出网络的数据流进行有选择的控制与操作。



包过滤技术



- 包过滤操作通常在选择路由的同时对数据包进行过滤。
- 可以设定一系列的规则，指定允许哪些类型的数据包可以流入或流出内部网络；哪些类型的数据包的传输应该被拦截。
- 包过滤规则以IP包信息为基础，对IP包的源地址、目的地址、封装协议、端口号等进行筛选。

包过滤技术



- 数据包过滤路由器的缺点：

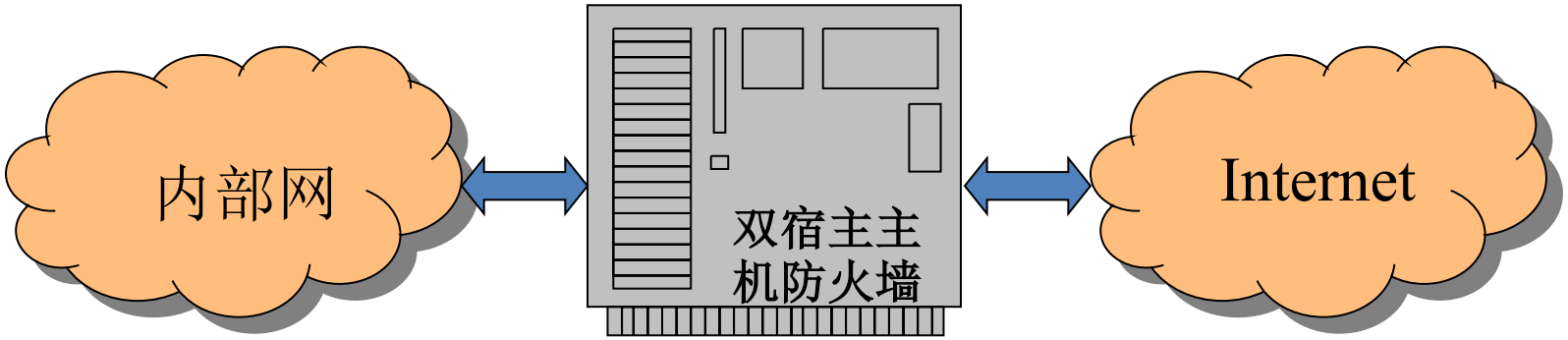
1. 包过滤配置复杂，过滤数目增加，网络效率下降；
2. 不能对付数据驱动攻击；
3. 不能对付IP地址欺骗攻击。

应用代理



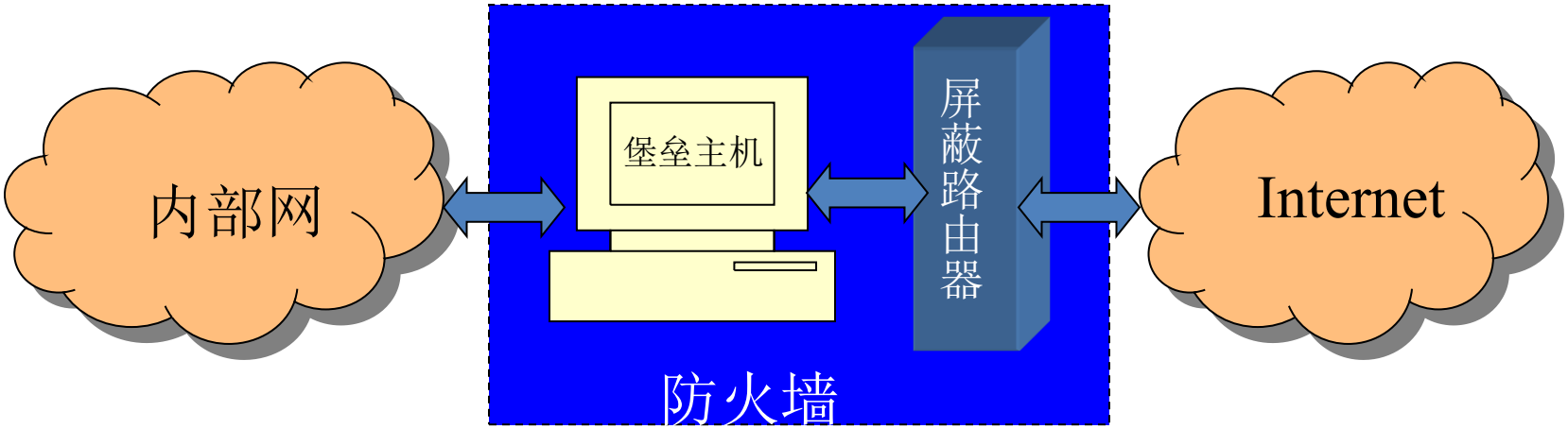
- 应用代理或代理服务器(Application-Level Proxy or Proxy Server)是代理内部网络用户与外部网络服务器进行信息交换的程序。
- 它将内部用户的请求确认后送至外部服务器，同时将外部服务器的响应再回送给用户。
- 设置专门的代理系统来完成防火墙的功能，这相当于将防火墙的任务交给专业公司来完成。专门的代理系统一般由代理服务器来实现。

双宿主主机结构



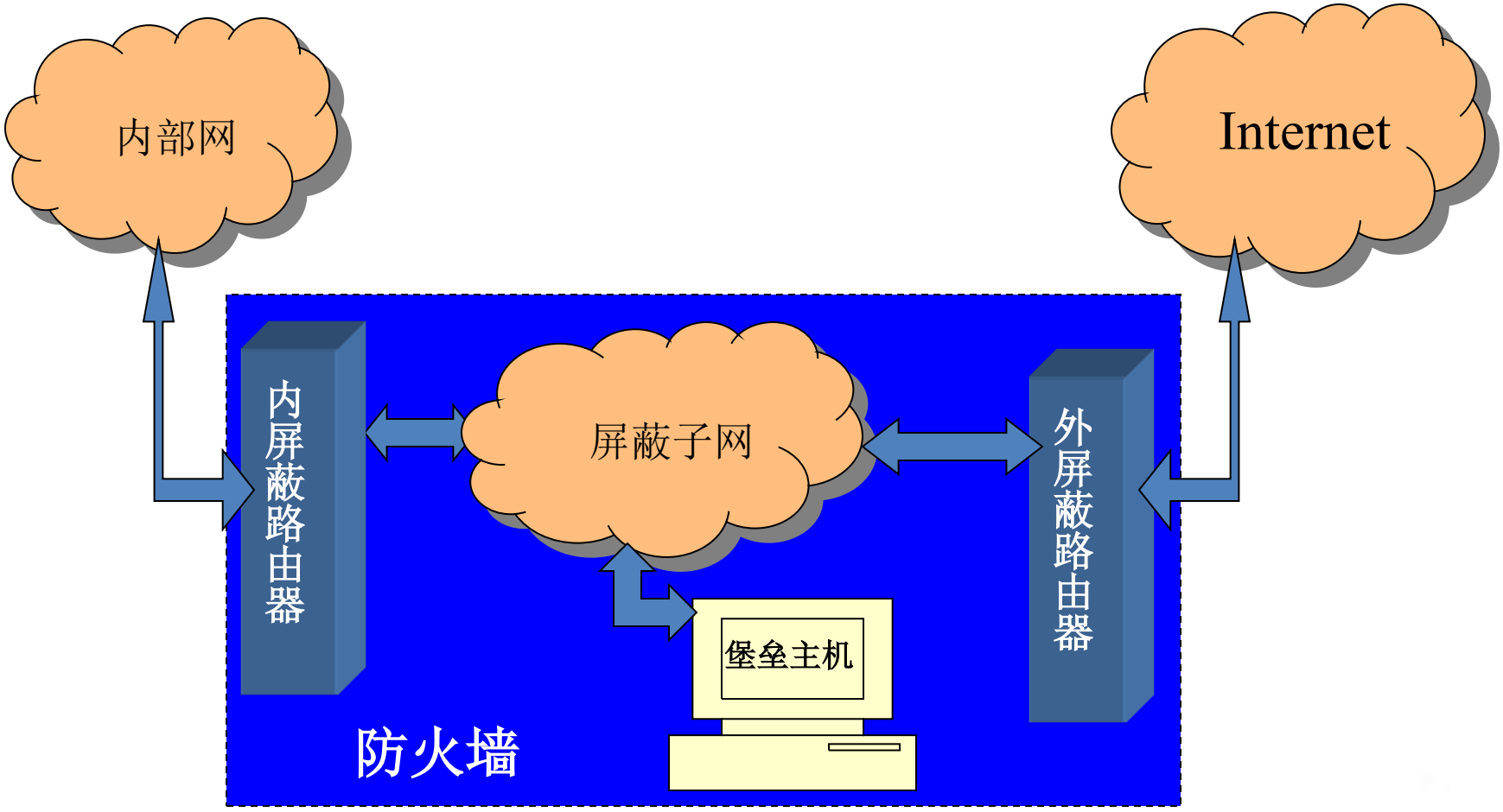
- 使用一个双宿主主机完成防火墙功能
- 双宿主主机不允许两网之间的数据直接传送，内网与外网通信时，必须由双宿主主机转发，即网络之间的IP通信完全被阻止，双宿主主机提供代理服务。
- 缺点是依赖单一部件保护系统，一旦被攻破，网络安全遭破坏。

屏蔽主机结构



- 屏蔽主机防火墙由屏蔽路由器、堡垒主机结合构成防火墙。
- 堡垒主机系统健壮，能抗攻击。对外提供一定的服务。
- 外部主机只能通过堡垒主机才能得到系统内部服务。
- 堡垒主机是唯一暴露在因特网中的主机，要攻击系统，只能通过攻击堡垒主机完成。

屏蔽子网结构



屏蔽子网结构



- 防火墙由外屏蔽路由器、屏蔽子网、堡垒主机和内屏蔽路由器共同组成。
- 一般内部网对外提供服务的服务器容易遭到攻击，一旦被攻破将作为进一步攻击内部网的跳板。
- 有了屏蔽子网，最坏的情况是子网中的服务器和堡垒主机被损坏，但内部网的完整性不被破坏。
- 两个屏蔽路由器消除了内部网络的单一侵入点
- 堡垒主机充当各种服务的代理服务器

§7.3 加密技术

- 密码学是研究编制密码和破译密码的技术科学。研究密码变化的客观规律，应用于编制密码以保守通信秘密的，称为编码学；应用于破译密码以获取通信情报的，称为破译学，总称密码学。
- 密码学的首要目的是隐藏信息的涵义。
- 密码是通信双方按约定的法则进行信息特殊变换的一种重要保密手段。依照这些法则，变明文为密文，称为加密变换；变密文为明文，称为脱密变换。

专业术语

1. 明文：没有进行加密，能够直接代表原文含义的信息。
2. 密文：经过加密处理处理之后，隐藏原文含义的信息。
3. 加密：将明文转换成密文的实施过程。
4. 解密：将密文转换成明文的实施过程。
5. 密码算法：密码系统采用的加密方法和解密方法，随着基于数学密码技术的发展，加密方法一般称为加密算法，解密方法一般称为解密算法。
6. 密钥：加密、解密过程中的关键参数。分为加密密钥和解密密钥。

密钥的作用

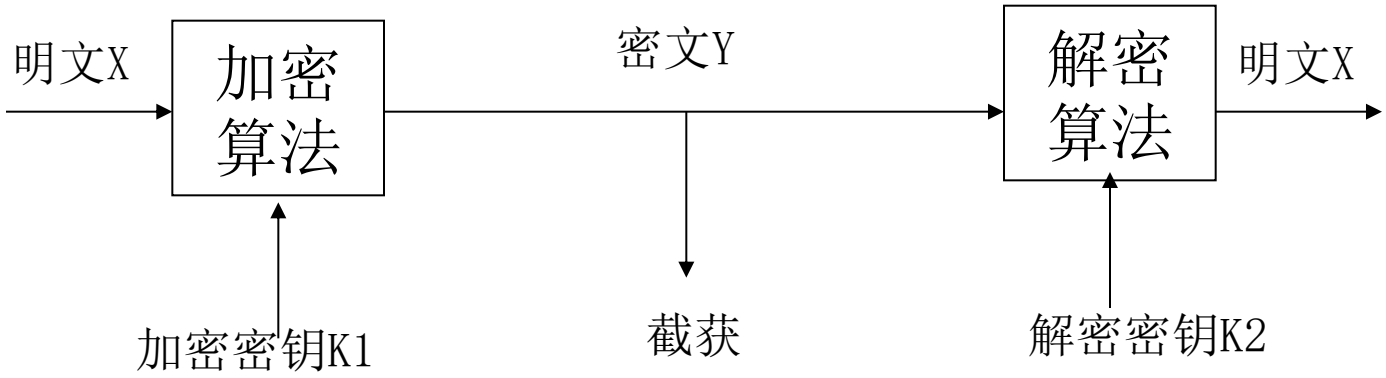


- 虽然实际上加密法通常还是有用的，破解一个信息需要知道是使用何种加密法，因此才会促成了谍报、贿赂、窃盗或背叛等行为。
- 直到十九世纪学者们才认识到加密法的算法并非理智或实在的防护。实际上，适当的密码学机制（包含加解密法）应该保持安全，即使敌人知道了使用何种算法。
- 信息论始祖克劳德·艾尔伍德·香农（Claude Shannon）重述：“敌人知道系统。”
- 对好的加密法来说，钥匙的秘密性理应足以保障资料的机密性。这个原则首先由奥古斯特·柯克霍夫（Auguste Kerckhoffs）提出并被称为柯克霍夫原则（Kerckhoffs' principle）。

§7.3 加密技术

- 加密(Encryption)是指将称为明文(Plain Text)的信息经过加密钥匙(Encryption Key)及加密函数变成密文(Cipher Text)的过程。
- 接收方经过解密函数和解密钥匙(Decryption Key)再将其还原成明文。

一般数据加密模型



- 在发送端，明文X通过加密算法和加密密钥K1处理变成密文Y；
- 在接收端，密文Y通过解密算法和解密密钥K2处理变成明文X；
- 在进行解密运算时，如果不使用事先约定好的解密密钥K2，就无法解出明文X；
- 截获者正是因为没有解密密钥K2，而无法得到明文X。

加密技术的实现方式

- 加密技术可以在通信的三个层次来实现：链路加密、节点加密和端到端加密。
- 链路加密、节点加密在网络路由器上实现，是网络的事情；用户可做的是端到端加密。

端到端加密：用户加密



- 源端对数据进行加密，直到目标端才对数据进行解密。只需要一次加、解密。
- 加密由数据发送者在源端进行，解密由数据接收者在目标端进行。

1、对称加密算法



- 收信方和发信方使用相同的密钥，即加密密钥和解密密钥是相同或等价的，称为对称加密，又称为单钥加密体制。
- 在众多的对称密码中影响最大的是数据加密标准(Data Encryption Standard，DES)。
- DES加密算法是一种分组加密方法，需要将数据文件分成若干个大小为64位(比特)的组。一组64位(比特)的明文，在64位密钥的控制下产生64位的密文；反之输入64位的密文，则输出64位的明文。

DES算法---加密工作过程

1. 给定一个64比特明文分组x，通过一个固定的初始转换IP置换x的比特顺序获得x_0，记$x_0 = IP(x) = L_0R_0$

   L_0是x_0的前32比特，R_0是x_0的后32比特。

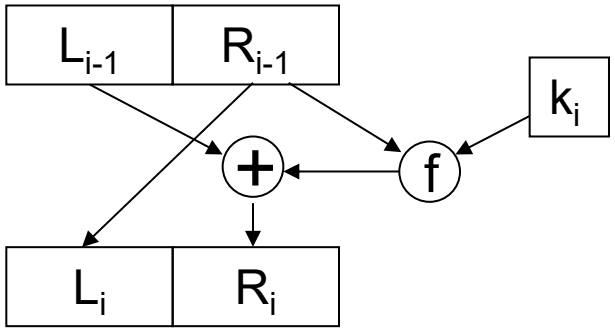
   IP置换：只是改变x的比特顺序。 IP置换，以后解释。

2. 进行16轮计算

   异或

$$L_i = R_{i-1}, \quad R_i = L_{i-1} \oplus f(R_{i-1}, k_i)$$

DES算法---加密工作过程



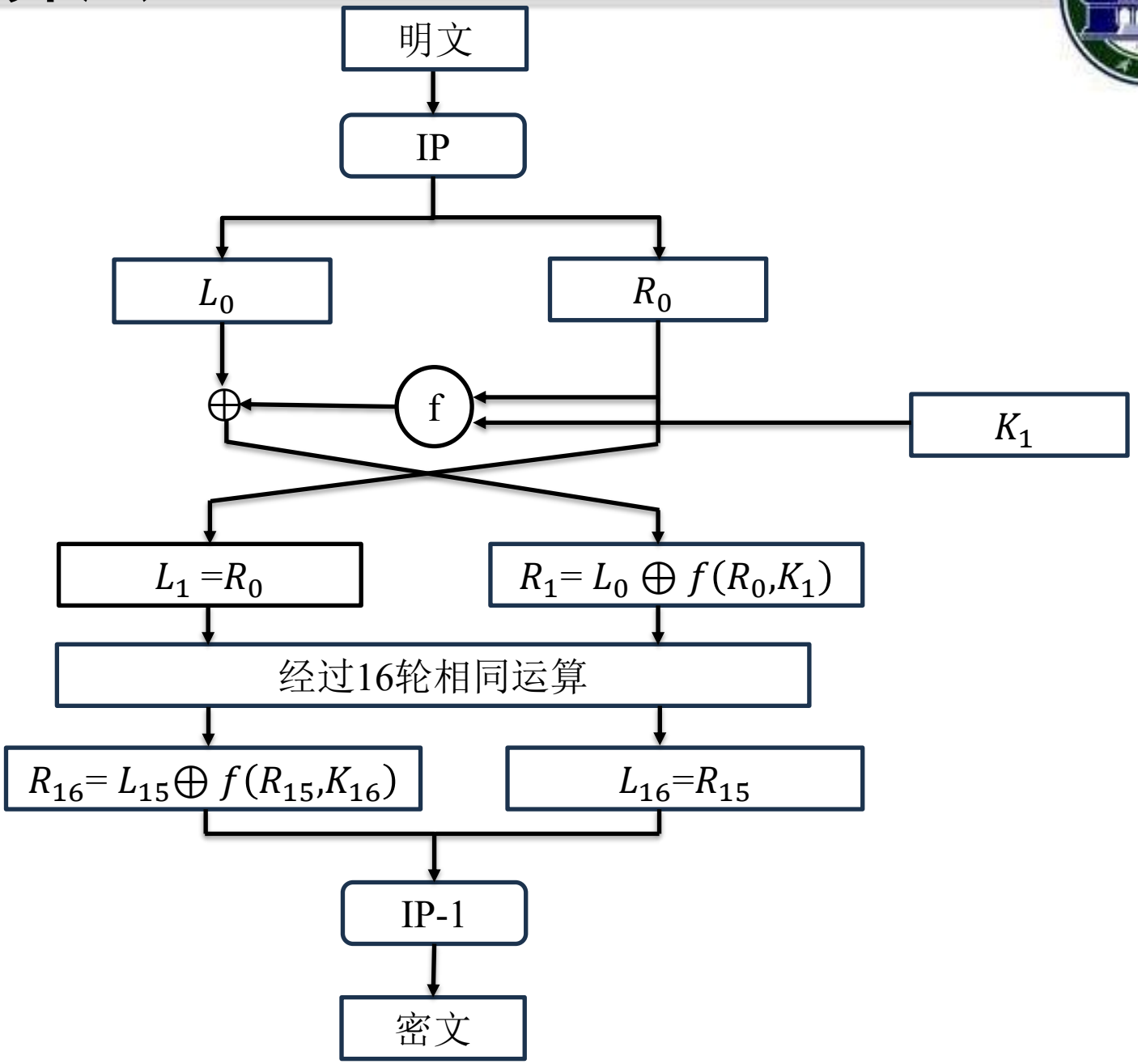
函数f(A,J),A:32比特串,J:48比特串

k_i:第i轮DES加密密钥

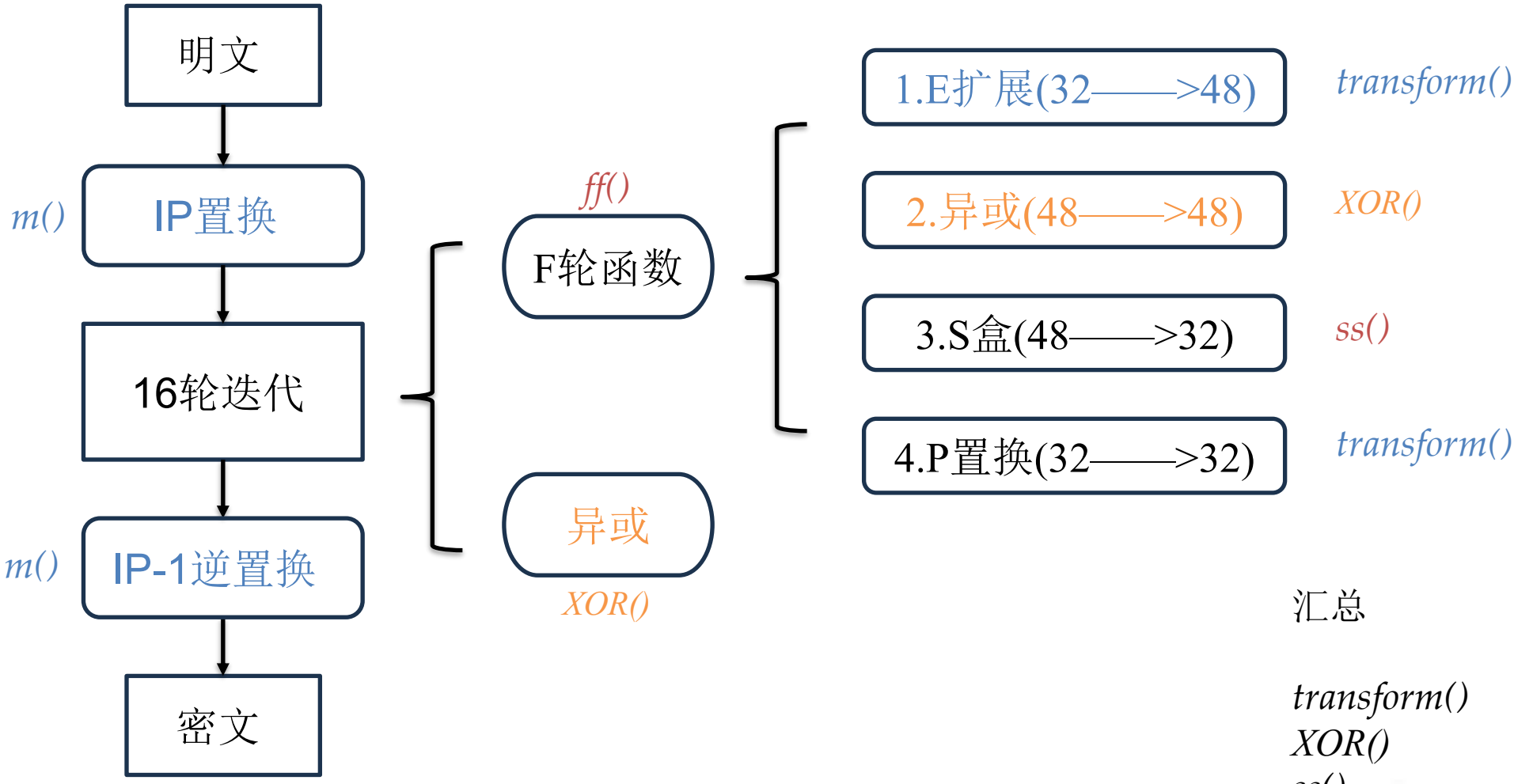
问题：k_i从何而来，函数f(A,J)怎样计算？以后解释

3. 对$R_{16}L_{16}$进行逆置换IP^{-1}，获得密文y，加密完成。整个加密过程表示：y=DES（x，$k_{i=1,\cdots,16}$）
4. 解密采取同一算法完成，把密文作为输入，倒过来使用密钥，即使用顺序：k_{16}，k_{15}，……，k_1，输出得到明文x。整个解密过程表示：x=DES（y，$k_{i=16,\cdots,1}$）

DES算法


明文
IP
L_0
R_0
f
K_1
$L_1 = R_0$
$R_1 = L_0 \oplus f(R_0, K_1)$
经过16轮相同运算
$R_{16} = L_{15} \oplus f(R_{15}, K_{16})$
$L_{16} = R_{15}$
IP-1
密文

DES算法


明文
m()
IP置换
16轮迭代
m()
IP-1逆置换
密文
ff()
F轮函数
异或
XOR()
1.E扩展(32——>48)
transform()
2.异或(48——>48)
XOR()
3.S盒(48——>32)
ss()
4.P置换(32——>32)
transform()
汇总
transform()
XOR()
ss()

DES算法---IP置换



该算法要将分组不断置换位置，要应用初始置换IP及逆置换IP^{-1}。置换表示：$x_0=IP(x)$

置换IP

58	50	42	34	26	18	10	2
60	52	44	36	28	20	12	4
62	54	46	38	30	22	14	6
64	56	48	40	32	24	16	8
57	49	41	33	25	17	9	1
59	51	43	35	27	19	11	3
61	53	45	37	29	21	13	5
63	55	47	39	31	23	15	7

逆置换IP^{-1}

40	8	48	16	56	24	64	32
39	7	47	15	55	23	63	31
38	6	46	14	54	22	62	30
37	5	45	13	53	21	61	29
36	4	44	12	52	20	60	28
35	3	43	11	51	19	59	27
34	2	42	10	50	18	58	26
33	1	41	9	49	17	57	25

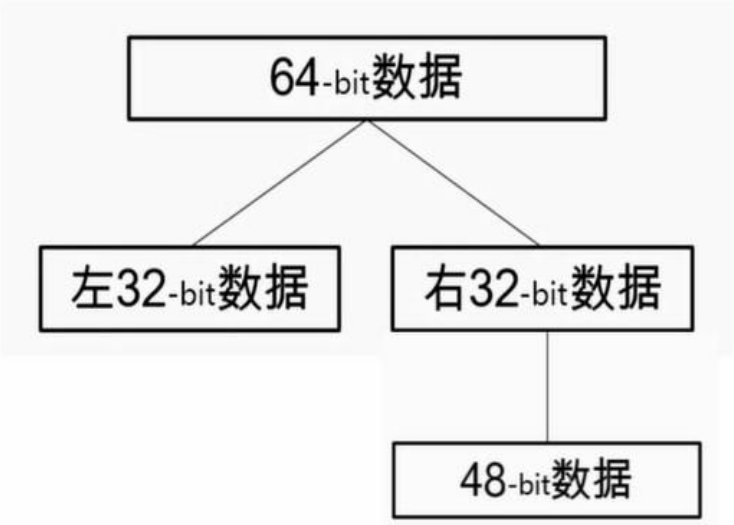
这意味着x的58比特变成x_0的第1比特，x的50比特变成x_0的第2比特，依次类推。

初始置换在于打乱x的划分关系；没有密码意义。

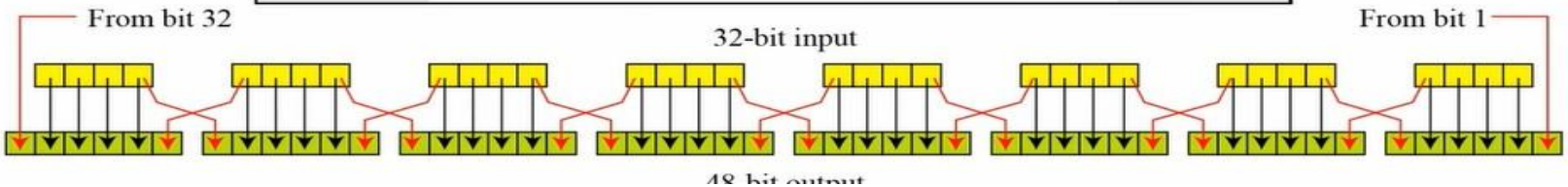
DES算法---轮函数

1）E扩展置换

将32位输入扩展为48位输出



32	01	02	03	04	05
04	05	06	07	08	09
08	09	10	11	12	13
12	13	14	15	16	17
16	17	18	19	20	21
20	21	22	23	24	25
24	25	26	27	28	29
28	29	31	31	32	01



DES算法---轮函数

1）轮函数——E扩展置换

1 1 0 1 0 0 0 1 0 0 1 1 0 1 0 0
0 0 1 0 0 0 1 1 0 0 1 1 1 0 1 1



1 1 1 0 1 0 1 0 0 0 1 0 1 0 0 1 1 0 1 0 1 0 0 0
0 0 0 1 0 0 0 0 0 1 1 0 1 0 0 1 1 1 1 1 0 1 1 1

扩展置换
置换表

32	1	2	3	4	5	4	5	6	7	8	9
8	9	10	11	12	13	12	13	14	15	16	17
16	17	18	19	20	21	20	21	22	23	24	25
24	25	26	27	28	29	28	29	30	31	32	1

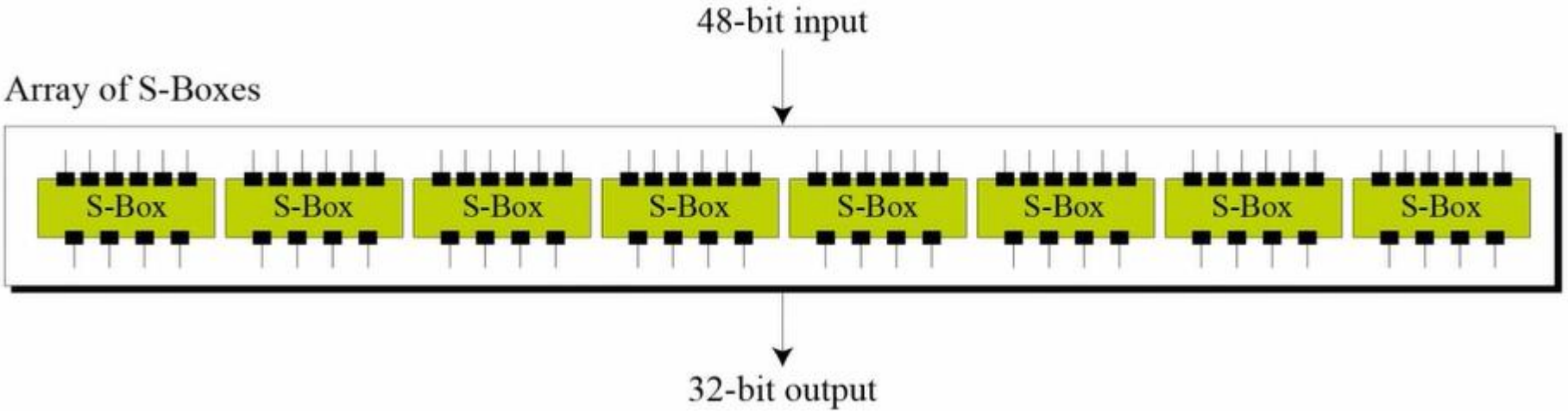
1 1 1 0 1 0 | 1 0 0 0 1 0 | 1 0 0 1 1 0 | 1 0 1 0 0 0

0 0 0 1 0 0 | 0 0 0 1 1 0 | 1 0 0 1 1 1 | 1 1 0 1 1 1

DES算法---轮函数

2）S盒压缩处理

- 经过扩展的48位明文和48位密钥进行异或运算后，再使用8个S盒压缩处理得到32 位数据
- 将48位输入等分为8块，每块6位输入压缩为4位输出



DES算法---轮函数

2）S盒压缩处理

8个6进4出S盒

行 \ 列		0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15
S_1	0	14	4	13	1	2	15	11	8	3	10	6	12	5	9	0	7
	1	0	15	7	4	14	2	13	1	10	6	12	11	9	5	3	8
	2	4	1	14	8	13	6	2	11	15	12	9	7	3	10	5	0
	3	15	12	8	2	4	9	1	7	5	11	3	14	10	0	6	13
S_2	0	15	1	8	14	6	11	3	4	9	7	2	13	12	0	5	10
	1	3	13	4	7	15	2	8	14	12	0	1	10	6	9	11	5
	2	0	14	7	11	10	4	13	1	5	8	12	6	9	3	2	15
	3	13	8	10	1	3	15	4	2	11	6	7	12	0	5	14	9
S_3	0	10	0	9	14	6	3	15	5	1	13	12	7	11	4	2	8
	1	13	7	0	9	3	4	6	10	2	8	5	14	12	11	15	1
	2	13	6	4	9	8	15	3	0	11	1	2	12	5	10	14	7
	3	1	10	13	0	6	9	8	7	4	15	14	3	11	5	2	12
S_4	0	7	13	14	3	0	6	9	10	1	2	8	5	11	12	4	15
	1	13	8	11	5	6	15	0	3	4	7	2	12	1	10	14	9
	2	10	6	9	0	12	11	7	13	15	1	3	14	5	2	8	4
	3	3	15	0	6	10	1	13	8	9	4	5	11	12	7	2	14
S_5	0	2	12	4	1	7	10	11	6	8	5	3	15	13	0	14	9
	1	14	11	2	12	4	7	13	1	5	0	15	10	3	9	8	6
	2	4	2	1	11	10	13	7	8	15	9	12	5	6	3	0	14
	3	11	8	12	7	1	14	2	13	6	15	0	9	10	4	5	3
S_6	0	12	1	10	15	9	2	6	8	0	13	3	4	14	7	5	11
	1	10	15	4	2	7	12	9	5	6	1	13	14	0	11	3	8
	2	9	14	15	5	2	8	12	3	7	0	4	10	1	13	11	6
	3	4	3	2	12	9	5	15	10	11	14	1	7	6	0	8	13
S_7	0	4	11	2	14	15	0	8	13	3	12	9	7	5	10	6	1
	1	13	0	11	7	4	9	1	10	14	3	5	12	2	15	8	6
	2	1	4	11	13	12	3	7	14	10	15	6	8	0	5	9	2
	3	6	11	13	8	1	4	10	7	9	5	0	15	14	2	3	12
S_8	0	13	2	8	4	6	15	11	1	10	9	3	14	5	0	12	7
	1	1	15	13	8	10	3	7	4	12	5	6	11	0	14	9	2
	2	7	11	4	1	9	12	14	2	0	6	10	13	15	3	5	8
	3	2	1	14	7	4	10	8	13	15	12	9	0	3	5	6	11

DES算法---轮函数

2）S盒压缩处理

1111111001011100
1100110001100101
0111111011011000



对于6比特变量Bj= b1b2b3b4b5b6,用b1b6对应整数r(0 ≦r≦3)用b2b3b4b5对应整数c(0 ≦c≦15), Sj(Bj)的取值就是Sj矩阵第r行c列的整数对应的二进制表示(4比特)。

DES算法---轮函数

3）P盒置换

S盒位再经过P盒置换。至此，一次轮函数操作完毕

P 盒置换表							
16	7	20	21	29	12	28	17
1	15	23	26	5	18	31	10
2	8	24	14	32	27	3	9
19	13	30	6	22	11	4	25

DES算法---秘钥生成



要从种子密钥k（64比特），导出16个48比特密钥k_i。 K的第8, 16, 24, ……, 64比特将被扔掉，实际只有56比特。 k_i导出方法：

① 用置换 PC-1置换出k的56比特，即PC-1(k) = C_0D_0， C_0是PC-1(k) 的前28比特，D_0是PC-1(k)的后28比特

② 对每个i(1<=i<=16)，计算C_i=LS_i (C_{i-1})， D_i=LS_i (D_{i-1})， k_i=PC-2 (C_i D_i)。LS_i表示一个或两个位置的左循环移位，i=1, 2, 9, 16时移动一位， i为其他数时移动两位

③ PC-2表示一个置换，每7个比特一组丢弃最后一个比特，由56比特C_iD_i导出48比特k_i

DES算法---秘钥生成

0001 0011 0011 0100

0101 0111 0111 1001

1001 1011 1011 1100

1101 1111 1111 0001

PC-1						
57	49	41	33	25	17	9
1	58	50	42	34	26	18
10	2	59	51	43	35	27
19	11	3	60	52	44	36
63	55	47	39	31	23	15
7	62	54	46	38	30	22
14	6	61	53	45	37	29
21	13	5	28	20	12	4

1111000 0110011

0010101 0101111

0101010 1011001

1001111 0001111

PC-2					
14	17	11	24	1	5
3	28	15	6	21	10
23	19	12	4	26	8
16	7	27	20	13	2
41	52	31	37	47	55
30	40	51	45	33	48
44	49	39	56	34	53
46	42	50	36	29	32

C_0 = 1111000 0110011 0010101 0101111

D_0 = 0101010 1011001 1001111 0001111

移位次数表

第*i*次迭代	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16
循环左移次数	1	1	2	2	2	2	2	2	1	2	2	2	2	2	2	1

C_1=1110000 1100110 0101010 1011111

D_1=1010101 0110011 0011110 0011110

K_0=000110 110000 001011 101111 111111 000111 000001 110010

对称加密算法评价



- DES算法的主要优点是加解密速度快，算法容易实现，安全性好。是常用的加密算法。
- 最主要的问题是：由于加解密双方要使用相同的密钥，在发送和接收数据之前，就必须完成密钥的分发。因此，密钥的分发成了该加密体系中的最薄弱的环节。

- 密钥的分发手段：距离近的采用人工送达的方式；距离远的采用网络安全通道的方式。

2、公开密钥密码体制



- 加密密钥不同于解密密钥，它们是一对，即用其中一把钥匙加密得到的密文，只能用另一把钥匙解密才能得到明文。这种密码体制中，存在两把对应的密钥，所以又叫双钥体制。
- 解决了密钥分发的难题。加密密钥公之于众，任何人都可以使用；解密密钥只有解密人自己知道。它们分别称为公开密钥(Public Key)和私有密钥(Private Key)。
- 公钥(uK)和私钥(rK)组成一对密钥，用公(私)钥加密的密文，只能由私(公)钥解密才能得到明文。
- 比较著名的公钥密码算法有：RSA、背包密码、McEliece密码、Diffe-Hell man、Rabin、Ong-Fiat-Shamir、零知识证明算法、椭圆曲线和ElGamal算法等等。最有影响的公钥密码算法是RSA。

RSA公开密钥密码系统



- RSA公开密钥密码系统是由R.Rivest、A.Shamir和L.Adleman教授于1977年提出的。RSA的取名就是来自于这三位发明者姓氏的第一个字母。
- 第一个较完善、研究得最广泛的双钥算法，经历了各种攻击的考验，公认为最优秀的双钥算法之一。
- 该算法的数学基础是数论。安全性建立在大整数分解难题之上。
- 一旦因子分解问题的研究取得进展， RSA双钥体制的安全性将受到极大的挑战。

RSA公开密钥密码系统



- RSA算法的安全性是建立在大数分解这一数学难题上：n=p×q，p和q是两个大素数。由p和q分别用单向陷门函数生成公钥和私钥。其中n对外公开（加密或解密时要使用）。
- 破解理想途径：

  n（公开）→p, q→单向陷门函数（公开）→公钥和私钥
- 要破解RSA密码系统只能寄希望于由n找出p和q

  21：3, 7　　49：7, 7　　12741：？

RSA公开密钥密码系统



- 计算机编程的因子求解：

```
i=2;
while(n%i!=0) i++;
 {p=i;      q=n/p;} ;
```

- n非常大， 二进制位数达到384，512，768，1792，2304位。一般上述程序需要运行若干小时，若干天，若干月，若干年。时间太长，走不通
- 寄希望数学方法解决大数分解问题。分解这样的大数，在数学上尚未解决。

RSA算法（1）

◊ 预备知识：

1. 素数：只能被1和本身整除的整数。
2. mod：模运算，a mod b，结果为a ÷ b的余数，上式读为，a模b 或a的模b运算。若a mod b = c mod b，则a ， c称为同模，记为

$$a \equiv c \bmod b$$

3. 求幂算法(平方-乘)：计算 $x^e \bmod n$

已知$e=e_{L-1}e_{L-2}\cdots e_0$且$e_{L-1}=1$，计算 $x^e \bmod n$

```
z=1
for i=L-1 down to 0 do
    z=z^2 mod n
    if e_i=1 then z=z*x mod n
```

RSA算法（2）

- RSA密码算法描述：
- 设一对足够大的素数为p和q(为保证算法具有最大的安全性，它们长度应该相同或相近)，则它们的乘积为n=pq。 n的欧拉数为 $\phi(n)=(p-1)(q-1)$。选取适当的加密密钥e和解密密钥d，使之满足 $ed \equiv 1 \mod \phi(n)$。

  公开n和e, 保密p, q和d。

  加密运算： $y=E_k(x)=x^e \mod n, \quad x \in Z_n$

  解密运算： $x=D_k(y)=y^d \mod n, \quad y \in Z_n$

RSA算法（3）



◊ RSA算法密码系统步骤如下：

1. 生成两个大素数p, q;
2. 计算n=pq, $\phi(n)=(p-1)(q-1)$;
3. 选择数e（加密密码）， e与$\phi(n)$互素;
4. 计算解密密码d，$de=1 \mod \phi(n)$;
5. 公布整数n和加密密码e。

◊ 双钥体制运作方式：

1. 数据接收者将加密密码e和n传给对方
2. 数据发送者用e和n对明文加密，传给对方
3. 数据接收者用解密密码d和n对密文解密。

◊ 要破解密码，只能由n推出p，q，这很难。加密密码e和n可广为分发，解密密码d只有所有者一人才有，因此可以保密。

RSA算法（4）

由e计算模反元素d

如果两个正整数e和φ(n)互质，那么一定可以找到一个整数d，使得ed-1被φ(n)整除，或者说ed除以φ(n)所得余数为1。此时，d就叫做e的模反元素。

例：
如3和11互质，可找到4，3*4-1=11

RSA算法（5）

RAS过程示例

S1：p=3，q=11

S2：n=p*q=33

S3：$\phi(n)=(p-1)*(q-1)=2*10=20$

S4：e=3

S5：计算密码d，满足 de mod $\phi(n)=1$ （3d mod 20=1，d=7）

S6：公钥（e,n）=（3，33）

S7：私钥(d,n）=（7，33）

加密运算：$y=Ek(x)=x^e \bmod n$，$x \in Zn$

X = 20，$y= 20^3 \bmod 33=14$

解密运算：$x=Dk(y)=y^d \bmod n$，$y \in Zn$

$X= 14^7 \bmod 33= 20$

RSA公开密钥密码系统评价



- 由于RSA采用加密与解密双钥制，即一把是用户的专用密钥，另一把是其他用户都可利用的公共密钥，因此，使用方便，安全可靠。
- 在RSA的硬件实现中， RSA比DES慢1500倍，在软件实现上， RSA比DES慢100倍。一般用来加密小数据，如数字签名、密码等。
- 混合加密体制(安全通道)

用双钥加密体制作为安全通道传送单钥加密密钥，然后用单钥加密算法传送数据。

§7.4 报文鉴别技术

- 数据加密—对付被动进攻，数据的保密性
- 报文鉴别—对付主动进攻中的数据篡改、伪造、删除，数据的完整性
- 对付报文篡改的两种方法：
  - 1，拒绝修改，用在资源子网系统中，用访问控制技术实现；
  - 2，能够及时发现数据被篡改、伪造，用报文鉴别技术

§ 7.4 报文鉴别技术

- 报文鉴别技术
  - 工作原理类似于数据校验技术
  - 发送方根据数据计算一个鉴别码；接收方对接收数据用同样方法再计算一个鉴别码；与接收的鉴别码比较，得出数据是否有变化的结论

§7.4 报文鉴别技术



◊ 基于报文鉴别码的鉴别技术

- 报文鉴别码(message authentication code, MAC)机制的核心是报文鉴别函数C_k( )。
- 该函数以报文内容作为输入，通过某种运算得到一个较短的定长数据分组，使用一个密钥对定长数据分组进行加密得到定长码MAC作为函数的输出，即MAC= C_k(M)。
- MAC被附加在报文中传输，用于消息合法性的鉴别。
- 接收方根据得到的原文和MAC, 用相同方法重新计算MAC。若与接收MAC相同，可确认收到的消息是合法的。

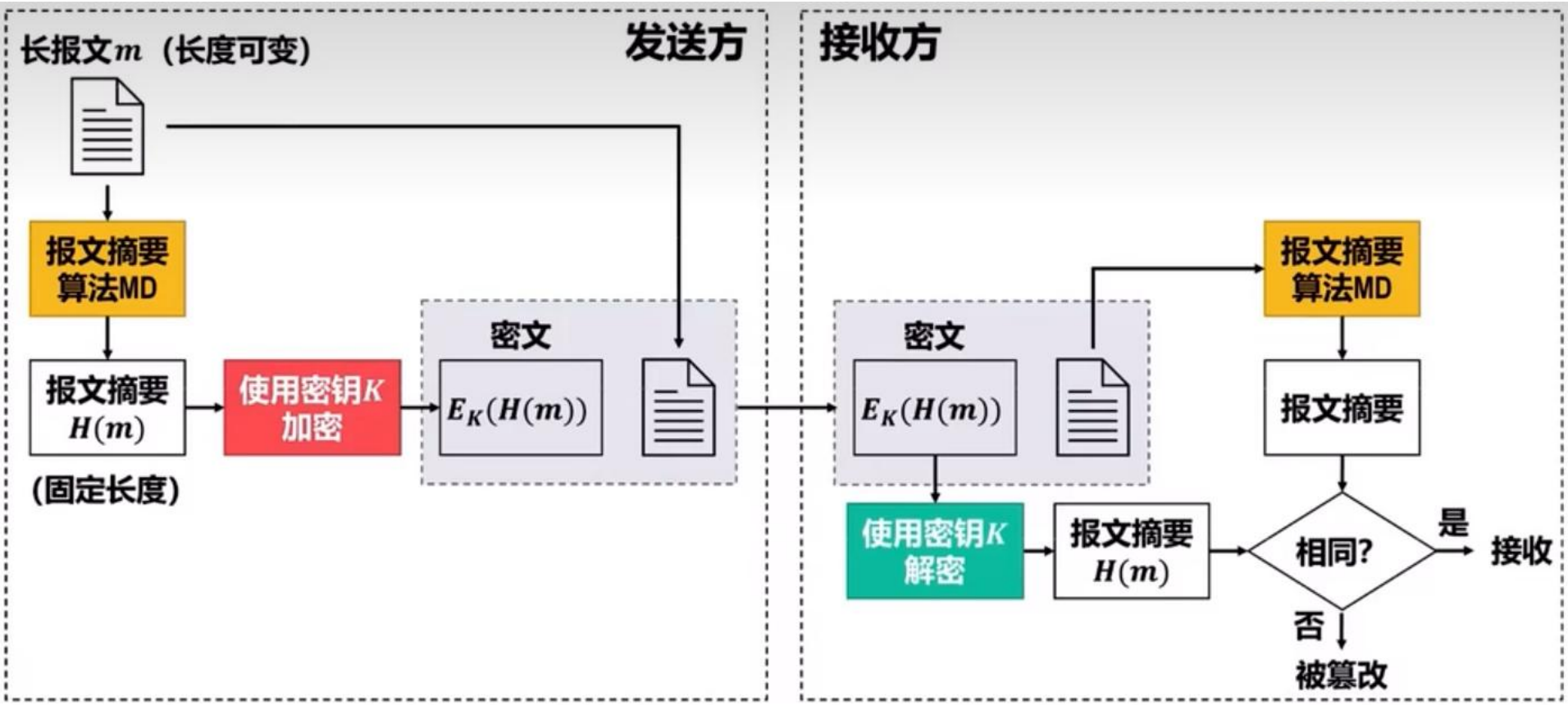
§7.4 报文鉴别技术

- 基于报文鉴别码的鉴别技术(cont.)
  - 攻击者修改原文而未改MAC， 接收方通过计算MAC可发现原文被篡该。
  - 攻击者不知密钥k，因此无法伪造一个与修改后的原文匹配的MAC。

  - Ck(M)函数的基本要求
    - 输入消息M是变长的，输出结果MAC定长
    - 运用密钥k进行加密，即MAC= Ck(M) = Ek(△(M))

    例如△(M)的一种计算方法可以设计为：
    - △(M)=M1⊕M2 ⊕ ……⊕ Mt
    - 其中被划成了若干个64比特的段，最后一段Mt必须被补充到64比特。

§7.4 报文鉴别技术



使用报文摘要对报文进行鉴别的好处是：只对长度固定且比整个报文长度短得多的报文摘要$H(m)$进行加密，比对整个报文m进行加密要简单得多。

§7.4 报文鉴别技术



◊ 基于散列函数的鉴别技术

- □ 基于散列函数的鉴别技术与基于报文鉴别函数的鉴别技术原理基本相同，是报文鉴别码技术的变种。

- □ 散列函数（hash函数）比报文鉴别函数复杂，用于密码学的散列函数需具备以下属性：
  - ○ 单向性：无法通过散列结果倒推输入数据
  - ○ 难分析：对输入数据的微小修改会造成散列结果的巨大改变
  - ○ 无冲突/碰撞：在计算上，无法根据散列函数的输入输出，求解相同输出条件下的另一个不同输入。

散列函数



- 著名的散列函数构造方法有：MD5消息摘要算法，安全散列算法SHA-1，RIPEMD-160散列算法等。

MD5算法



1. 填充文件，使其长度为模512余448位；填充内容是第一位为1，其余为0。
2. 将文件原始长度值以64位二进制数表示，并将这64位二进制数填充文件最后部分，形成512整数倍。
3. 设置四个32位变量：A=0x01234567, B=0x89abcdef, C=0xfedcba98, D=0x76543210。

MD5算法

4. 读文件一个分组（512位），将其分成16个32位分组M_i
5. 设a=A，b=B，c=C，d=D。
6. 依次对M_i进行四轮计算：

① $a=b+(a+F(b,c,d)+M_i+t_i)<<<s$

② $b=c+(b+G(c,d,a)+M_i+t_i)<<<s$

③ $c=d+(c+H(d,a,b)+M_i+t_i)<<<s$

④ $d=a+(d+I(a,b,c)+M_i+t_i)<<<s$

常数

循环左移s位

非线性函数

常数t_i为：
t_i=int(232*abs(sin(i)))
s为预先设定的随机数

MD5算法



7. A+=a, B+=b, C+=c, D+=d
8. 循环6，7直到所有M_i运算完毕
9. 循环4~8直到所有分组运算完毕
10. 级联A,B,C,D，得到128位散列码。算法结束。

◊ 非线性函数为：

$F(a,b,c)=(a\cap b)\cup((-a)\cap c)$

$G(a,b,c)=(a\cap c)\cup(b\cap(-c))$

$H(a,b,c)=a\oplus b\oplus c$

$I(a,b,c)=b\oplus(a\cup(-c))$

§7.5 身份认证与数字签名



- 身份认证：用户身份的确认技术。
- 账号+密码方法是一种身份认证，主要用于用户进入系统时的查验
- 对数字签名的识别过程也是一种身份认证，主要用于检查接收到的文件不是伪造的，确由合法用户发来。
- 数字签名(Digital Signatures)：是一组数据，能够使接收方证实发送方的真实身份，防止发送方事后否认已发送过的报文，鉴别非法伪造、篡改报文等行为。

数字签名设计目标

- 数字签名是一组与消息报文相关的比特串
- 由于与消息报文存在相关关系，数字签名还能对消息内容进行鉴别
- 数字签名对发送者来说必须是唯一的，只有发送者能够生成该数字签名.　因此能够防止伪造和抵赖
- 产生数字签名的算法必须简单，且能够在存储介质上保持备份
- 对数字签名的识别、证实、鉴别必须简单
- 无论攻击者采用什么方法，伪造数字签名在计算上是不可行的

直接数字签名方案



- 发送方A使用私钥对消息报文的散列码进行加密形成数字签名
- 接收方B使用A的公钥对数字签名进行解密得到散列码，并用散列码检查消息报文
- 因为只有A拥有私钥，所以该签名只有A能够形成，对此A无法抵赖，B也可以确信消息报文确实来自A
- 其他人没有A的私钥，因此没法伪造A的签名。没有使用私钥加密的伪造签名，无法通过公钥的检验
- 如果A抵赖，B可以找到第三方，用A的公钥加以验证。
- 报文和签名可以保存在存储介质中，以备解决争端时使用。

直接数字签名方案



- 对整个报文和签名进行进一步加密的方法有很多种。不论采用何种方式加密，第三方必须拥有解密密钥，才能查看报文和签名。
- 由于签名来自于加密的散列码，因此数字签名依赖于消息报文的内容
- 报文和签名可以保存在存储介质中，以备解决争端时使用。